

Third-Party Risk Radar

System Design & Architecture

Continuous, cited vendor risk intelligence built on Bright Data live web infrastructure

Hackathon: Web Data UNLOCKED — Enterprise AI, Bright Data (San Francisco)

Buyer personas: Security (vendor risk) · Finance (portfolio risk) · GTM (competitor risk)

Bright Data products used: SERP API · Web Unlocker · Web Scraper API · MCP

Third-Party Risk Radar

Continuous, cited vendor risk intelligence — built on Bright Data live web infrastructure

1 · INPUT LAYER

vendors.csv

{ name, domain, weight } × N vendors

2 · COLLECTION LAYER — BRIGHT DATA (LIVE WEB)

Async parallel collectors per vendor - every result carries its real source URL

SERP API

Discovery - freshness engine
"*<vendor>* data breach"
"*<vendor>* layoffs / lawsuit"
"*<vendor>* CVE / acquisition"
time-filtered to recent

Web Unlocker

Fetch bot-walled pages
breach trackers, paywalled news,
regulatory / court filings

403 → 200 (the proof)

Web Scraper API

Structured pulls, fixed sources
vendor status / trust pages
CVE listings, company profiles
clean JSON, no brittle parsers

raw HTML / text + source URLs

3 · EXTRACTION LAYER — LLM (CLAUDE API)

Strict extraction → locked JSON schema

{ vendor, category, severity 1-5, summary, source_url, date_detected }
categories: Security · Financial · Operational · Regulatory · Reputational
classification only - no invented facts - no source_url → signal dropped

4 · SCORING + STATE LAYER

Weighted Scoring

severity × vendor weight
→ 0-100 risk score / vendor
critical vendors weighted higher

State Store (SQLite)

persist every run snapshot
history per vendor / signal

Delta Alerting

diff vs last snapshot
surface only NEW signals
scraper → monitoring system

5 · INTERFACE LAYER

Dashboard (React / Streamlit)

sortable vendor table + color-coded scores
drill-down → signals with clickable
real source links
"new since last run" alert feed
Judges click a source → it resolves → trust

MCP Server

get_vendor_risk(vendor)
list_high_risk_vendors()
whats_new_since(date)

Claude queries it live, with citations

agent-native differentiator

DEMO PROOF POINTS — everything live, nothing mocked

Freshness

live SERP run on stage,
results dated today

Unblockability

naive fetch 403 vs
Web Unlocker 200

Auditability

every signal → real,
clickable source URL

Agent-native

Claude + MCP answers
"what's new this week?"

One engine, three buyer personas — GTM (competitors) · Finance (portfolio) · Security (vendors)

1. The Problem

Every enterprise depends on hundreds to thousands of third-party vendors — SaaS tools, cloud providers, payment processors, contractors. Each is an attack surface and a financial liability. When a vendor is breached, goes bankrupt, is acquired, cuts its security team, or faces regulatory action, the dependent company is exposed — and usually finds out weeks late, from a headline or an auditor.

Current third-party risk management relies on annual security questionnaires (stale the day they are filled out), expensive opaque scoring vendors, or an analyst manually searching vendor names. The unsolved problem is **continuous, real-time, cited risk intelligence from the live web**. The hard part is not the AI — it is data access: breach trackers, regulatory portals, status pages, and news are bot-protected, rate-limited, geo-walled, or buried in search. This is precisely the gap Bright Data fills, which makes it the right foundation for this project: the hard part *is* the sponsor's product.

2. Architecture Overview

Five layers. Stages 1–3 touch the live web through Bright Data; stages 4–5 turn raw signals into workflow-ready, agent-queryable intelligence. See the diagram on the cover page.

Input	A CSV of vendors: name, domain, and a criticality weight. The weight lets a critical vendor score higher for the same severity.
Collection (Bright Data)	Async parallel collectors per vendor. SERP API for discovery and freshness; Web Unlocker to fetch bot-walled pages; Web Scraper API for structured pulls from fixed sources. Every result carries its real source URL.
Extraction (LLM)	Raw text into Claude with a locked JSON schema. Classification and extraction only — no invented facts. A signal with no source URL is dropped.
Scoring + State	Weighted aggregate risk score per vendor; persist each run to SQLite; diff against the last snapshot and surface only NEW signals (delta alerting).
Interface	A dashboard (scores, drill-down, cited sources, alert feed) and an MCP server exposing query tools so Claude can answer live with citations.

3. Core Data Model (Risk Signal)

Every collected and extracted item normalizes to one signal object:

```
{
  "vendor": "Salesforce",
  "category": "Security", // Security | Financial | Operational | Regulatory | Reputational
  "severity": 4, // 1-5
  "summary": "Salesloft-Drift OAuth token cascade reached 700+ orgs incl. connected Salesforce.",
  "source_url": "https://...", // REQUIRED - no URL, signal dropped
  "date_detected": "2026-05-15"
```

```
}
```

Vendor risk score = normalized sum of (severity × recency decay) × vendor weight, mapped to 0–100. Scores and signals are versioned per run so the delta engine can compute what is new.

4. Recommended Demo Vendor List

A **coherent real enterprise SaaS stack** — the vendors a mid-size B2B company actually pays for and depends on — not a grab-bag of headline names. Each flagged vendor maps to a genuine, web-verifiable incident, and several are **interconnected**, letting the demo show cascading third-party risk. **Re-verify each with a live SERP query on stage.**

Vendor	Stack role	Recent verifiable signal	Category
AWS	Cloud / infra	Baseline dependency; monitor regional outages / CVEs	Operational
Cloudflare	CDN / edge	Feb 2026 BYOIP/BGP outage (6h07m); Salesloft cascade	Op. / Security
Okta	Identity / SSO	Root of Cloudflare Atlassian compromise (stolen creds)	Security
Snowflake	Data warehouse	Apr 2026 Anodot integrator token breach hit customers	Security
Salesforce	CRM	Salesloft-Drift + Gainsight OAuth cascade, 700+ orgs	Security
GitHub	Source control	Salesloft attack began in GitHub repos	Security
CrowdStrike	Endpoint sec.	Named among Salesloft Drift-affected firms	Sec. / Op.
Slack	Comms	Targeted via connected-integration OAuth tokens	Security
Workday	HR / payroll	Holds most sensitive PII; monitor breach / regulatory	Regulatory
Datadog (control)	Observability	No recent incident — proves engine won't invent	Low risk

Why this list survives scrutiny: it is a stack any enterprise security or procurement lead would recognize as their own; the signals are **interconnected** (the Salesloft-Drift attackers moved from GitHub into AWS, stole OAuth tokens, and reached Salesforce and Slack at 700+ orgs including Cloudflare and CrowdStrike; the Cloudflare Atlassian breach traces back to the Okta breach), so the demo can show **cascading** third-party risk; and Datadog is a genuine low-risk control.

5. Tech Stack & Build Plan

Backend: Python + FastAPI, asyncio for parallel collectors. **Web data:** Bright Data SERP API, Web Unlocker, Web Scraper API (\$250 participant credits cover it). **LLM:** Claude API for extraction. **Storage:** SQLite (zero-setup, enough for delta state). **MCP:** thin Python MCP server exposing three tools. **Frontend:** React, or Streamlit if time is tight.

Team of three

- **A** — Bright Data collectors + the blocked-vs-unblocked proof
- **B** — extraction prompt, scoring, SQLite delta logic
- **C** — MCP server + dashboard + demo script

Day 1

Collectors returning real data → extraction producing clean JSON → SQLite persisting. End the day with one full vendor pipeline working end-to-end on live data.

Day 2

MCP + dashboard + delta alerts + polish. Rehearse the four-minute demo twice.

6. Demo Script (~4 minutes)

Hook (20s). Show the dashboard with ~10 real vendors and risk scores. "Enterprises learn their vendors are compromised from the news. We learn first."

Freshness (60s). Click a vendor; run collection live; new signals stream in with dates and source links; click a source — the real article opens.

Unblockability (40s). Side-by-side: naive fetch returns 403 / captcha, Web Unlocker returns 200. This is the most persuasive moment — it proves the infrastructure is load-bearing.

Agent-native (60s). Switch to Claude connected to the MCP server. Ask: "Which vendors had a new security issue this week, and should I worry?" The agent calls the MCP tools live and answers with citations.

Close (20s). "Continuous, cited, agent-queryable third-party risk — entirely on Bright Data. Repoint it at competitors for GTM or portfolio companies for Finance. Same engine."

7. Why It Wins

- **Uncrowded lane.** Most teams build GTM lead enrichment; this owns Security/Finance, which maps to bigger enterprise budgets and leads the event description.
- **Hard part = sponsor's product.** The demo is literally impossible without Web Unlocker + SERP API. Bright Data is load-bearing, not a checkbox.
- **Real, verifiable, cited.** Live queries, clickable sources, and the blocked-vs-unblocked moment build credibility senior engineers trust.
- **Agent-native via MCP.** Shows where enterprise AI is heading, not just scraping.
- **Generalizes.** One engine, three buyer personas — judges see a product, not a hack.